Model Kill-Switch Protocol | ארכיטקטורה

CASE STUDY: איפה כל דבר יושב

בשלב האפיון בנינו חלקים: חתימה, ועדה, שער, יומן. כל חלק הוא רעיון. אבל רעיון לא רץ על שום מחשב.

עכשיו מגיעה השאלה של מי שבונה: אילו תוכנות יש בפועל? מי מדבר עם מי? ומה קורה כשאחת מהן נופלת באמצע הלילה?

התשובה נקראת ארכיטקטורה. זו מפה של הרכיבים (כל רכיב הוא תוכנה אחת עם תפקיד אחד), של הקווים ביניהם, ושל מה שעובר בהם.

אפשר לצייר אותה בכמה רמות. נתחיל מרחוק, נתקרב, ואז נעמיד את המערכת למבחנים: נשלח פקודה, נזייף אותה, ונפיל רכיבים.

3.1 מבט על: רכיבים, תפקידים וממשקים

- **מישור בקרה:** איפה מחליטים. כאן נולדת הפקודה ונבדקת.
- **הפצה:** איך ההחלטה מגיעה לכל מקום.
- **מישור אכיפה:** איפה מבצעים. כאן הבקשות של המשתמשים נעצרות או עוברות.
- **תצפית:** מי שומר על השומר.
- **שכבה חוצה:** מפתחות ואמון שכל הרכיבים נשענים עליהם.

רכיב	תפקיד	ממשקים נכנסים	ממשקים יוצאים
גורם מוסמך	הכלי שבו חברי הוועדה יוזמים פקודה. הוא אוסף חתימות חלקיות מכמה אנשים ומאחד אותן לחתימה אחת.	החלטה של בני אדם.	פקודה חתומה אל השער.
שער בקרה	הדלת היחידה שדרכה נכנסות פקודות. הוא בודק חתימה, מספר חד פעמי וזמן, ומתאם עם מנוע המדיניות.	פקודות מהגורם המוסמך, ובקשות אוטומטיות מהניטור.	שאלות למנוע המדיניות, רישום ליומן, ופרסום החלטה לאפיק ההפצה.
מנוע מדיניות	מחליט לפי כללים כתובים מי מורשה לעשות איזו פעולה על איזה תחום.	שאלה מהשער: מי, מה, על מה.	תשובה: מותר או אסור, עם נימוק.
יומן שקיפות	כל פקודה שאושרה נרשמת בו, ואי אפשר למחוק או לשנות. כל אחד מבחוץ יכול לבדוק אותו.	פקודות מאושרות מהשער.	גרסה ציבורית לקריאה בלבד.
אפיק הפצה	צינור שמעביר כל שינוי מצב לכל שערי האכיפה, בכל האזורים, תוך שניות ובאותו סדר.	החלטות מהשער.	אירוע שינוי מצב לכל שער.
צי שערי אכיפה	שומר ליד כל שרת שמגיש את המודל. הוא מחליט על כל בקשה: להעביר או לחסום.	אירועי שינוי מצב מהאפיק, ובקשות משתמשים.	העברה למודל, או חסימה עם קוד 503.

רכיב	תפקיד	ממשקים נכנסים	ממשקים יוצאים
מטמון מקומי	עותק של המצב האחרון הידוע, שכל שער שומר אצלו על הדיסק.	כתיבה מהשער בכל עדכון.	קריאה כשהאפיק לא זמין.
שכבת הגשת המודל (חיצוני)	התשתית הקיימת שמריצה את המודל ועונה למשתמשים. היא לא חלק מהמערכת שבנינו.	בקשות שעברו את השער.	תשובות המודל.
ניטור עצמי	צופה במדדי ההגשה של כל שער ובדפוסי החתימה, ומחשב כמה משהו חריג ביחס לרגיל.	מדדים מהשערים.	בקשת עצירה, לא עצירה.
יומן אבטחה מרכזי	אוסף כל אירוע מכל הרכיבים: הצלחה, דחייה, חריגה. הצוות והמערכות האחרות מסתכלים עליו.	אירועים מכל הרכיבים.	התראות ודשבורד לצוות.
ניהול מפתחות	מחזיק את מפתחות החתימה ואת התעודות שבהן הרכיבים מזהים זה את זה. מחליף אותם אוטומטית.	בקשות הנפקה וחידוש.	חומר קריפטוגרפי שמוגבל בזמן.

הקווים בין הרכיבים

- **פקודה חתומה:** גורם מוסמך ← שער בקרה
- **שאלה ותשובה:** שער בקרה ← מנוע מדיניות
- **רישום:** שער בקרה ← יומן שקיפות
- **שינוי מצב:** שער בקרה ← אפיק הפצה
- **הפצה:** אפיק הפצה ← צי שערי אכיפה
- **העברה או חסימה:** צי שערי אכיפה ← שכבת הגשת המודל
- **עותק מקומי:** צי שערי אכיפה ← מטמון מקומי (קו תמיכה)
- **מדדים:** צי שערי אכיפה ← ניטור עצמי (קו תמיכה)
- **בקשת עצירה:** ניטור עצמי ← שער בקרה (קו תמיכה)
- **מפתחות:** ניהול מפתחות ← שער בקרה (קו תמיכה)
- **אירועים:** שער בקרה ← יומן אבטחה מרכזי (קו תמיכה)
- **אירועים:** צי שערי אכיפה ← יומן אבטחה מרכזי (קו תמיכה)

3.2 התאמה לאפיון: איזה רכיב משרת איזה פיצ'ר

#	פיצ'ר	רכיבים	איך
1	חתימה על כל פקודה	גורם מוסמך, שער בקרה, ניהול מפתחות	הכלי אוסף חתימות, השער בודק אותן מול המפתח ששמור בכספת.
2	אי-חזרה על פקודות	שער בקרה	בדיקת המספר החד פעמי רצה בשער, לפני מנוע המדיניות.
3	השער	צי שערי אכיפה, שכבת הגשת המודל	כל בקשה נבדקת מול המצב המקומי, בלי רשת.

#	פיצ'ר	רכיבים	איך
4	ועדה ולא אדם אחד	גורם מוסמך, שער בקרה, ניהול מפתחות	שלושה מתוך חמישה חותמים, והמפתחות מחולקים.
5	עצירה ממוקדת	מנוע מדיניות, שער בקרה, צי שערי אכיפה	התחום נבדק במנוע המדיניות ונשמר בדגל של כל שער.
6	כשהתשתית נופלת	צי שערי אכיפה, מטמון מקומי	השער עובר למדיניות השמורה אחרי חמש דקות של שתיקה.
7	שמירה על השומר	ניטור עצמי, יומן אבטחה מרכזי, שער בקרה	הניטור מזהה חריגה ומבקש עצירה דרך אותו שער.
8	כמה אזורים	אפיק הפצה, צי שערי אכיפה	האפיק משכפל בין אזורים, והשערים עובדים גם בניתוק.
9	ספריות למפתחים	צי שערי אכיפה, שכבת הגשת המודל	השער יושב לפני שכבת ההגשה, בלי שינוי בקוד שלה.
10	הדמיה לפני עצירה	גורם מוסמך, מנוע מדיניות, שער בקרה	הפקודה נבדקת עד שלב המדיניות בלי להתפרסם.
11	תפוגה אוטומטית	שער בקרה, יומן שקיפות, אפיק הפצה, צי שערי אכיפה	לכל עצירה זמן תפוגה, והחזרה אוטומטית עוברת את אותה הפצה.

3.3 עיצוב נתונים

נתונים שעוברים ולא נשמרים

- **SignedKillCommand:** הפקודה בדרך מהכלי אל השער. לא נשמרת כמו שהיא.
- **PolicyDecision:** השאלה והתשובה בין השער למנוע המדיניות.
- **StatePropagationEvent:** ההודעה הקטנה שיוצאת באפיק לכל השערים.
- **Heartbeat:** פעימת חיים. נשמר רק הזמן של האחרונה.

נתונים שנשמרים

- **LedgerEntry:** כל פקודה שאושרה נרשמת ביומן השקיפות ולא ניתנת למחיקה. זו הרשומה הרשמית של מה קרה ומתי.
- **GatewayLocalState:** המצב הנוכחי נשמר גם במרכז וגם אצל כל שער. כפילות מכוונת, בשביל כשהרשת נופלת.
- **AnomalyEvent:** כל חריגה שהניטור זיהה, עם הציון שלה, כדי לכוון מחדש את הרגיל.
- **RejectionRecord:** כל דחייה נשמרת ביומן האבטחה, ובמקרים מסוימים גם ביומן הציבורי. דחיות גלויות מחזקות אמון.

ההודעות המרכזיות

SignedKillCommand (מהגורם המוסמך אל שער הבקרה)

```
{
  "command_id": "c-7f3a",
  "action": "STOP",
  "scope": "model:alpha, region:eu",
  "nonce": "9b2e41",
  "timestamp": 1760270400,
  "expires_at": 1760284800,
```

```
  "signature": "a41f..."
}
```

שדה	סוג	למה הוא שם
action	STOP או RESUME	מה לעשות.
scope	טקסט	על מי זה חל.
nonce	מספר חד פעמי	בלעדיו אפשר לשלוח את אותה פקודה שוב.
timestamp	זמן	מתי נוצרה.
expires_at	זמן	מתי העצירה פגה מעצמה.
signature	בתים	החתימה המאוחדת של הוועדה.

PolicyDecision (בין שער הבקרה למנוע המדיניות)

```
{
  "request": {"signer": "key-3", "action": "STOP", "scope": "model:alpha"},
  "decision": "allow",
  "reason": "signer may stop model:alpha"
}
```

שדה	סוג	למה הוא שם
request.signer	מזהה מפתח	מי מבקש.
request.scope	טקסט	על מה.
decision	allow או deny	התשובה.
reason	טקסט	הנימוק לתשובה.

LedgerEntry (משער הבקרה ליומן השקיפות)

```
{
  "leaf_hash": "5d1c...",
  "command_id": "c-7f3a",
  "merkle_root_after": "e90b...",
  "signed_tree_head": "3a77...",
  "timestamp": 1760270401
}
```

שדה	סוג	למה הוא שם
leaf_hash	טביעת אצבע	טביעה של הפקודה.
merkle_root_after	טביעת אצבע	ראש העץ אחרי ההוספה.
signed_tree_head	חתימה	הראש בחתימת היומן.

StatePropagationEvent (משער הבקרה, דרך אפיק ההפצה, לכל שער אכיפה)

```
{
  "scope": "model:alpha, region:eu",
  "action": "STOP",
  "seq": 4821,
  "sth": "3a77..."
}
```

שדה	סוג	למה הוא שם
scope	טקסט	על מי זה חל.
action	STOP או RESUME	המצב החדש.
seq	מספר רץ	מספר סידורי.
sth	חתימה	הראש הנוכחי של היומן.

AutoStopRequest (מהניטור העצמי אל שער הבקרה)

```
{
  "source": "self-monitor",
  "scope": "model:alpha",
  "z_score": 4.7,
  "requested_action": "STOP"
}
```

שדה	סוג	למה הוא שם
source	טקסט	מי ביקש.
z_score	מספר	כמה החריגה חזקה.
requested_action	STOP	מה ביקשו.

פרשות דרכים: החלטות ארכיטקטורה

שליחה ישירה לכל שער או אפיק הפצה?

נבחר: אפיק הפצה. השער שולח הודעה אחת, והאפיק דואג שהיא תגיע לכולם, באותו סדר, גם אם חלק מהם איטיים או נופלים לרגע.

המחיר: עוד רכיב לתחזק, ועיכוב של שניות עד שהעדכון מגיע.

שער מרכזי אחד או שומר ליד כל שרת?

נבחר: שומר ליד כל שרת. ההחלטה נבדקת במקום, בלי פנייה לרשת, ולכן מהירה. ונפילה של שומר אחד פוגעת בשרת אחד בלבד.

המחיר: הרבה שומרים לנהל ולעדכן.

לשאול את המרכז בכל בקשה או לשמור עותק מקומי?

נבחר: עותק מקומי. בדיקה בזיכרון מהירה בהרבה, ועובדת גם כשהרשת נופלת. ההחלטה האחרונה תמיד שמורה אצל השומר.

המחיר: צריך לדאוג שהעותק מתעדכן, ולהחליט מה קורה כשהעדכון מתעכב.

שהניטור הפנימי יעצור בעצמו?

נבחר: הניטור מבקש. אם מי שזיהה את הבעיה גם מבצע, נוצר קיצור דרך שאפשר לנצל. כל בקשה עוברת את אותה שרשרת כמו כל פקודה אחרת.

המחיר: תגובה איטית יותר, כי צריך את הוועדה.

סדר בנייה: חמישה ספרינטים

- **ספרינט 1: שלד שעובד:** פקודה אחת חתומה עוצרת מודל אחד, מקצה לקצה. קודם בונים נתיב אחד שלם, גם אם הוא גס. כל השאר מצטרף אליו.
- **ספרינט 2: אימות מלא:** ועדה של שלושה מתוך חמישה, מספר חד פעמי ומנוע מדיניות. זו ההגנה הראשית. בלעדיה אין מנגנון, יש רק כפתור.
- **ספרינט 3: שקיפות והפצה:** יומן ציבורי, אפיק הפצה ואזורים מרובים. כשיש כמה שרתים ואזורים, בלי הפצה אין מערכת.
- **ספרינט 4: עמידות:** מטמון מקומי, מתג איש מת ונתיך. כאן המערכת מוכיחה שהיא לא נשברת כשהיא נשברת.
- **ספרינט 5: תצפית:** ניטור עצמי ויומן אבטחה. בונים אחרון, כי צריך מערכת עובדת כדי לנטר אותה.

בדיקה אחרונה: האם הכול סגור?

הרכיב היחיד מחוץ לגבולות הוא שכבת ההגשה של המודל, והיא תשתית קיימת. כל מה שמחליט, מפיץ ואוכף נמצא בפנים. גם בקשת העצירה האוטומטית של הניטור נכנסת דרך אותו שער.

זיהוי ואכיפה באותו מעגל, סגור מקצה לקצה.